

# AI Vendor Scoring Guide

Use this guide after the vendor has answered the questionnaire. The goal is not a single magic number. The goal is to land on a risk tier and a clear decision: approve, approve with conditions, reject, or request more information.

## Step 1 - Classify the use case first

Before scoring the vendor, classify what you are using the tool for. The same vendor can be acceptable for one use and unacceptable for another.

| Use case tier | Examples                                                                                                                                                  |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Low stakes    | Brainstorming, drafting internal memos, formatting, summarizing public documents, low-risk internal assistance.                                           |
| Medium stakes | Customer-facing copy with review, code assistance, internal data analysis, meeting summaries, support drafts, workflow recommendations.                   |
| High stakes   | Hiring, lending, pricing, housing, insurance, benefits, education, healthcare, legal services, safety, public services, or other consequential decisions. |

If the use case is high stakes, the vendor must clear a higher bar on every category below. Several answers that might be acceptable for low stakes should become high risk or unacceptable for high-stakes use.

## Step 2 - Score by category

For each category, note the weakest material answer. Do not average away a serious gap.

### A. Data sensitivity

| Data entered                                                                | Minimum review expectation                                                                                                      |
|-----------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Public information only                                                     | Basic terms, privacy policy, and acceptable security posture.                                                                   |
| Internal business information                                               | Contractual data protections, no-training commitment or documented controls, security documentation.                            |
| Customer or employee personal data                                          | DPA or equivalent, security report, encryption, deletion rights, subprocessors, retention terms.                                |
| Health, financial, biometric, children's, student, legal, or regulated data | Sector-specific review, appropriate agreements, access controls, retention limits, and qualified legal/privacy/security review. |
| Data held under NDA or contract                                             | Explicit contractual permission and confidentiality pass-through before use.                                                    |

If minimum expectations are not met for the actual data you would send, do not approve until resolved.

### B. Use of data for training or product improvement

- **Never:** strongest posture.
- **Only if customer opts in:** acceptable if opt-in status is confirmed and documented.
- **Yes by default, opt-out available:** acceptable only for low-risk uses after opt-out is confirmed.

- **Yes by default, no opt-out:** normally unacceptable except for public-data-only uses where the business accepts the risk.
- **Unknown:** more information needed before approval.

### C. Security posture

- No security documentation: acceptable only for very low-risk public-data use.
- No encryption at rest or in transit: reject for anything beyond public data.
- No MFA or SSO where multiple users will access business data: approve only with documented compensating controls or reject.
- Recent unresolved breach: escalate and usually reject until remediation is documented.
- No audit logs for business-critical or sensitive workflows: approve only with clear limits or reject.

### D. AI-specific controls

Downgrade or escalate if the vendor cannot explain:

- Prompt injection, jailbreak, and abuse controls.
- Hallucination and accuracy limitations.
- Safety, bias, or red-team testing relevant to the use case.
- Human review options.
- Change notices for model upgrades, feature changes, or deprecations.
- Guardrail configuration and admin controls.

### E. Legal, regulatory, and contractual fit

Escalate if the tool may touch:

- Decisions about people.
- Employment, hiring, education, credit, housing, insurance, healthcare, public services, legal services, or safety.
- EU/UK personal data.
- Health, financial, biometric, student, child, or other regulated data.
- Contractual confidentiality or NDA data.
- Public-facing claims, creative output, or content where IP risk matters.

The vendor does not need to answer legal questions for your organization. But if the vendor cannot provide basic contract, privacy, data, and transparency support, the tool may not be appropriate for the proposed use.

### F. Exit and continuity

Downgrade or reject if:

- There is no data export path.
- Post-termination deletion is unclear.
- There is no SLA or continuity posture for business-critical use.
- The vendor can materially change or remove the AI feature without notice.
- You cannot preserve evidence needed for customer, regulator, audit, or dispute inquiries.

## Step 3 - Choose a risk tier

| Tier | What it means                                                                          | Typical outcome                               |
|------|----------------------------------------------------------------------------------------|-----------------------------------------------|
| Low  | Public-data or low-impact internal use, strong enough vendor posture, minor gaps only. | Approve. Review annually or when use changes. |

|              |                                                                                                                                                 |                                                                                                        |
|--------------|-------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Medium       | Business data or customer-facing support with reasonable vendor posture and gaps that can be mitigated.                                         | Approve with conditions. Review in 6-12 months.                                                        |
| High         | Sensitive data, consequential use, regulated context, or major operational reliance where protections must be negotiated or reviewed.           | Approve only after qualified review and documented conditions, or pause. Review in 6 months or sooner. |
| Unacceptable | Serious gaps the vendor will not close, unclear data use, unsupported high-stakes use, or risk that cannot be made reasonable for the use case. | Reject. Document the reason. Revisit only if facts materially change.                                  |

## Step 4 - Document the decision

Record:

1. Final tier and decision.
2. Approved scope of use.
3. Conditions before first use.
4. Ongoing conditions.
5. Business owner.
6. Next review date.
7. Evidence reviewed.
8. Open questions or escalation notes.
9. Inventory/update tracker entry.

## Step 5 - Common approval conditions

Use these as starting points when approving with conditions:

- Public-data-only use.
- No customer, employee, student, health, financial, legal, confidential, or regulated data.
- Human review before external use.
- No decisions about people.
- SSO and MFA enabled before rollout.
- Vendor DPA signed before use.
- Training/product-improvement opt-out confirmed before first use.
- Use limited to named team or pilot group.
- Output must be labeled, fact-checked, or reviewed before publication.
- Re-review after 90 days, 6 months, annual renewal, vendor model change, or workflow expansion.

## Disclaimer

This document is a template for educational and informational purposes only. It is not legal advice and does not create an attorney-client relationship. Consult qualified counsel and appropriate privacy, security, procurement, HR, and technical reviewers before relying on this guide for legal compliance, regulated use cases, sensitive data use, or vendor approval decisions.